

Q/CUP

中国银联股份有限公司企业标准

Q/CUP 047.3—2014
代替Q/CUP 047.3-2012

中国银联 IC 卡技术规范——产品规范 第 3 部分 动态口令应用规范

China UnionPay integrated circuit card specification
—product specification
Part 3 Dynamic Password Specifications

2014-11-30 发布

2014-11-30 实施

中国银联股份有限公司发布

中国银联股份有限公司（以下简称“中国银联”）对该规范文档保留全部知识产权权利，包括但不限于版权、专利、商标、商业秘密等。任何人对该规范文档的任何使用都要受限于在中国银联成员机构服务平台（<http://member.unionpay.com/>）与中国银联签署的协议之规定。中国银联不对该规范文档的错误或疏漏以及由此导致的任何损失负任何责任。中国银联针对该规范文档放弃所有明示或暗示的保证，包括但不限于不侵犯第三方知识产权。

未经中国银联书面同意，您不得将该规范文档用于与中国银联合作事项之外的用途和目的。未经中国银联书面同意，不得下载、转发、公开或以其它任何形式向第三方提供该规范文档。如果您通过非法渠道获得该规范文档，请立即删除，并通过合法渠道向中国银联申请。

中国银联对该规范文档或与其相关的文档是否涉及第三方的知识产权（如加密算法可能在某些国家受专利保护）不做任何声明和担保，中国银联对于该规范文档的使用是否侵犯第三方权利不承担任何责任，包括但不限于对该规范文档的部分或全部使用。

目 录

1. 范围.....	1
2. 规范性引用文件.....	1
3. 术语和定义.....	1
3.1. 集成电路卡（IC 卡）.....	1
3.2. 金融 IC 卡.....	1
3.3. 动态口令.....	1
3.4. 动态口令终端.....	2
3.5. 应用密文.....	2
3.6. IAD 发卡行应用数据.....	2
3.7. ATC 应用交易计数器.....	2
3.8. CVR 卡片验证结果.....	2
3.9. 数值的表示.....	2
4. 符号和缩略语.....	2
5. 认证工作原理.....	3
5.1. 原理概述.....	3
5.2. 卡片功能说明.....	4
5.3. 读卡终端工作原理.....	5
5.4. 发卡行认证工作原理.....	5
6. 业务流程.....	6
6.1. 功能概述.....	6
6.1.1. 应用选择.....	7
6.1.2. 应用初始化.....	7
6.1.3. 读应用数据.....	7
6.1.4. 终端行为分析.....	7
6.1.5. 动态口令生成.....	7
6.1.6. 交易结束.....	7
6.2. 交易流程图.....	7
7. 指令与实施说明.....	8
7.1. 应用选择.....	8
7.1.1. 命令.....	8
7.1.2. 后续相关流程.....	9
7.2. 应用初始化.....	9
7.2.1. 命令.....	9
7.2.2. 处理流程.....	9
7.2.3. 前期相关处理.....	9
7.2.4. 后续相关处理.....	10
7.3. 读应用数据.....	10
7.3.1. 命令.....	10
7.3.2. 处理流程.....	10
7.3.3. 前期相关处理.....	10
7.3.4. 后续相关处理.....	10
7.4. 终端行为分析.....	10

7.4.1. 概述.....	10
7.4.2. 命令.....	11
7.4.3. 处理流程.....	11
7.4.4. 前期相关处理.....	11
7.4.5. 后续相关处理.....	11
7.5. 动态口令有效数据生成.....	11
7.5.1. 命令.....	11
7.5.2. 处理流程.....	11
7.5.3. 前期相关处理.....	11
7.5.4. 后续相关处理.....	12
7.6. 交易结束.....	12
7.6.1. 概述.....	12
7.6.2. 前期相关处理.....	12
7.7. 交易过程中所需数据.....	12
7.7.1. CDOL1、CDOL2、PDOL 涉及到的数据定义.....	12
7.7.2. CVR 数据定义	13
8. 动态口令构建及显示.....	15
8.1. 加密算法.....	15
8.2. 动态口令有关数据构建.....	15
8.3. 动态口令有效位选择.....	15
8.4. ATC 异或	15
8.5. 有效位移位规则.....	15
8.6. 动态口令显示.....	16
9. 发卡行认证服务.....	16
9.1. 认证服务介绍.....	16
9.2. 认证服务基本框架示意图.....	17
9.3. 认证服务器参考流程.....	18
9.4. 失步处理.....	18
9.5. 数据管理.....	19
9.5.1. 卡片数据.....	19
9.5.2. 终端数据.....	20
9.6. 算法.....	20
9.7. 风险管理.....	20
10. 其他要求.....	21
10.1. 读卡终端硬件要求.....	21
10.1.1. 显示屏.....	21
10.1.2. 输入.....	21
10.1.3. IC 卡读卡器.....	21
10.1.4. 电池.....	21
10.2. 读卡终端软件要求.....	21
10.3. 读卡终端安全要求.....	21
10.4. 余额查询.....	21
附录：应用模式推荐.....	22

前 言

本标准是依据《中国银联IC卡技术规范》以及其它相关的标准制定。

本标准阐述了中国银联UICS金融IC卡基于非接触小额支付的扩展应用相关内容。

本标准由中国银联股份有限公司提出。

本标准由中国银联股份有限公司产品部组织制定。

本标准主要起草单位：中国银联产品部。

本标准主要起草人：肖波、李春欢、海涛、于维。

中国银联 IC 卡技术规范——应用规范

第 3 部分 动态口令应用规范

1. 范围

本规范对基于《中国银联 IC 卡技术规范》的金融 IC 卡借贷记应用的动态口令应用做出了相关要求和规定,包括应用原理、有关数据、动态口令生成和显示、发卡行验证方式等,适用于开展互联网、电话等非面对面支付的地区、成员机构以及商户。

金融 IC 卡动态口令应用是通过符合《中国银联 IC 卡技术规范》的金融 IC 卡借贷记应用和动态口令终端,按照《中国银联金融 IC 卡动态口令应用规范》联合生成一次性金融 IC 卡脱机授权摘要信息的产品应用。

动态口令数据信息是金融 IC 卡交易授权相关的应用密文、ATC 和 IAD 等数据的信息摘要,作为金融 IC 卡对银行卡非面对面交易的脱机授权和身份认证的主要模式。

2. 规范性引用文件

下列文件中的条款通过本标准的引用而成为本标准的条款。凡是注明日期的引用文件,其随后所有的修改单(不包括勘误的内容)或修订版均不适用于本标准,然而,鼓励根据本标准达成协议的各方研究是否可使用这些文件的最新版本。凡是不注明日期的引用文件,其最新版本适用于本标准。

《中国银联 IC 卡技术规范——基础规范 第 1 部分:借记贷记应用规范》

《中国银联 IC 卡技术规范——基础规范 第 2 部分:借记贷记应用卡片规范》

《中国银联 IC 卡技术规范——基础规范 第 4 部分:借记贷记应用安全规范》

3. 术语和定义

本标准采用下列术语和定义:

3.1.

集成电路卡 (IC 卡)

内部封装一个或多个集成电路用于执行处理和存储功能的卡片

3.2.

金融 IC 卡

符合《中国银联 IC 卡技术规范》借记/贷记应用的 IC 卡

3.3.

动态口令

动态口令也称动态密码,是根据专门的算法生成一个不可预测的随机数字组合,每个口令只能使用一次。

3.4.

动态口令终端

使用金融 IC 卡生成动态口令并显示的设备

3.5.

应用密文

应用密文是指在 **GENERATE AC** 命令发出后，由卡片使用应用密文子密钥对来自终端和卡片的数据加密生成的 8 字节的密文。这些数据包括卡片风险管理参数列表对象标识的部分数据和卡片内部的动态数据。密文类型包括 TC（脱机批准），ARQC（联机）和 AAC（拒绝）。

3.6.

IAD 发卡行应用数据

发卡行应用数据是 Q/CUP 045 必备数据，用来把 Q/CUP 045 定义的数据传送给终端，然后被放到联机请求报文或清算报文中。此数据中包括的数据元有：

长度指针、分散密钥索引、密文版本信息、卡片验证结果（CVR）、算法标识、发卡行自定义数据（可选）

3.7.

ATC 应用交易计数器

自卡片个人化以后处理的交易数量，在终端频度检查中使用

3.8.

CVR 卡片验证结果

根据本次和上次交易脱机处理结果进行设置的验证结果指示符。

3.9.

数值的表示

本规范中采用下列数值符号：

十进制数值用数字本身表示（例如：数字 1）

十六进制数值的表示是将数值加上引号，并且前面加上 x（例如：数值 x'01'）

二进制数值的表示是将数值加上引号，并且前面加上 b（例如：数值 b'00000001' 或 b'1'）

Bit 1 表示低位(0x01)，Bit 8 表示高位(0x80)

4. 符号和缩略语

以下符号和缩略语表适用于本规范

AAC	应用认证密文(Application Authentication Cryptogram)
AC	应用密文(Application Cryptogram)
AFL	应用文件定位器(Application File Locator)
AID	应用标识符(Application Identifier)
AIP	应用交互特征(Application Interchange Profile)

ARQC	授权请求密文(Authorization Request Cryptogram)
ATC	应用交易序号(Application Transaction Counter)
CDOL	卡片风险管理数据对象列表(Card Risk Management Data Object List)
CVR	卡片验证结果(Card Verification Results)
CVN	卡片验证值(Card Verification Number)
DDA	动态数据认证(Dynamic Data Authentication), 在脱机认证中可以防止伪卡, 卡片对交易中的特定数据产生RSA签名用于终端验证
DKI	子密钥索引(Derivation Key Index)
FCI	文件控制信息(File Control Information), 当读写器或终端选择卡片应用(使用SELECT命令)时, 由卡片响应返回
GPO	获取处理选项(GET PROCESSING OPTIONS)
ISO	国际标准化组织
UICS	UICS借记/贷记应用。本规范中的UICS指支持接触界面, 完全符合EMV 4.1要求的应用
PDOL	处理选项数据对象列表(Processing Options Data Object List)。卡片需要的终端数据对象的一个列表
PIN	个人识别码(Personal Identification Number)
RFU	保留(Reserved for Future Use)
SDA	静态数据认证(Static Data Authentication)
SFI	短文件标识符(Short File Identifier)
TC	交易证书(Transaction Certificate), 当接受交易时产生的应用密文
TLV	标签、长度、值(Tag Length Value)
UDK	唯一分散密钥, 用于计算过程密钥, 生成应用密文。

5. 认证工作原理

5.1. 原理概述

本规范涉及一种基于金融 IC 卡的动态口令认证技术。其基本原理是基于卡片, 将由读卡终端发出的数据源, 通过 **GENERATE AC** 的方式, 生成响应, 并对响应结果进行处理, 形成用于用户认证使用的动态口令。在用户认证时, 动态口令会上传至发卡行的认证服务器端。认证服务器对上传的动态口令进行处理, 一方面提取出部分数据, 用于之后的比对认证; 另一方面通过动态口令中所包含的信息, 重新构建与卡片中相同的 **GENERATE AC** 过程, 并进行处理后得到用于认证的部分数据。将两个部分数据进行比对, 比对结果用于认证。

具体流程如下图所示:

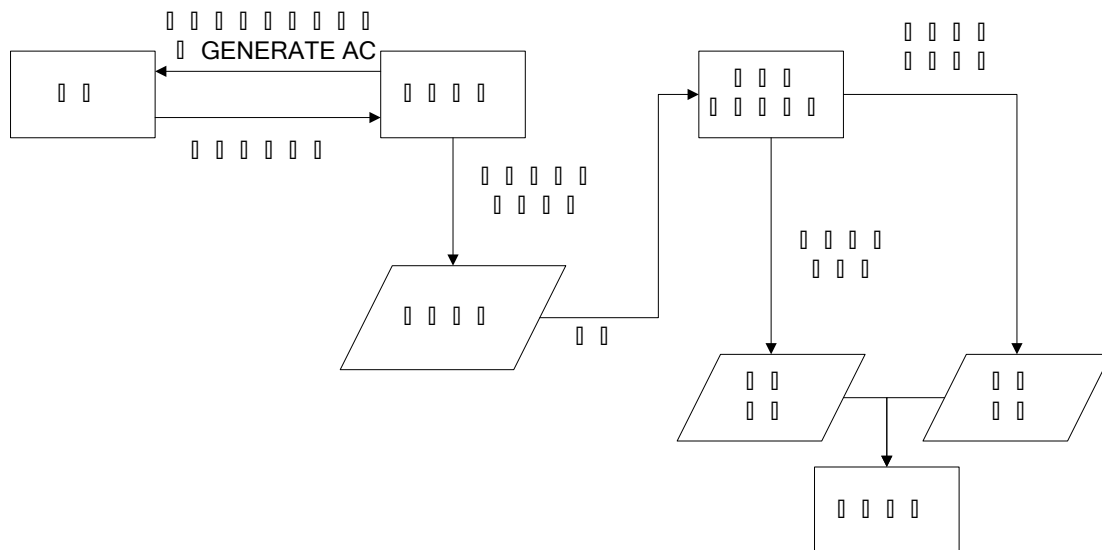


图 1：动态口令认证工作原理

5.2. 卡片功能说明

金融 IC 卡在生成动态口令的过程中，主要功能在于对由读卡终端发送的数据源，根据 GENERATE AC 过程进行运算，生成包含应用密文 AC 在内的 GENERATE AC 响应。该过程符合 UICS 2012 版规范中的相关过程与要求。

具体原理如下图所示：

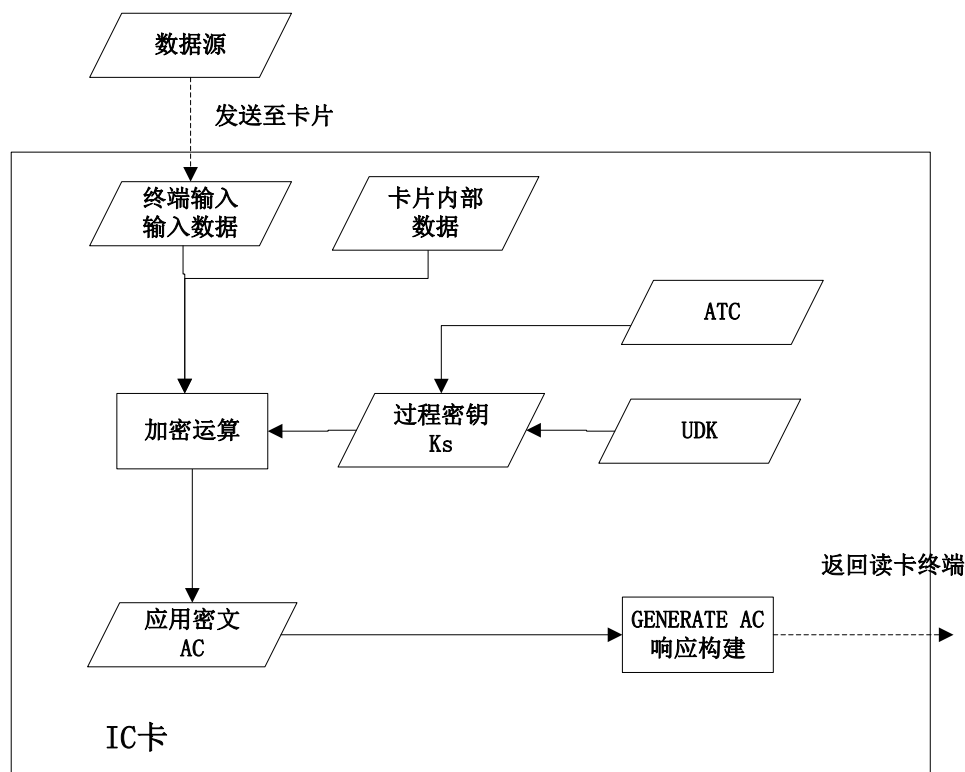


图 2：卡片内部工作原理

卡片在收到由读卡终端发至的数据源后，将该数据源作为输入数据，开始进行 GENERATE AC 的流程。卡片使用 UDK（唯一分散密钥）在 ATC 的参与下，生成过程密钥 K_s 。然后，使用 K_s 对来自终端的数据 D 及卡片内部的有关数据进行加密运算，生成应用密文 AC。卡片构

建包含 CID、ATC、AC、IAD 的 GENERATE AC 的响应，并将响应返回读卡终端。

5.3. 读卡终端工作原理

读卡终端在动态口令生成过程中，主要负责为卡片提供数据源并发起 GENERATE AC 这个过程，同时在收到 GENERATE AC 的响应后，对响应进行压缩和转换的处理，得到用户可见的、用于认证的动态口令。

具体原理如下图所示：

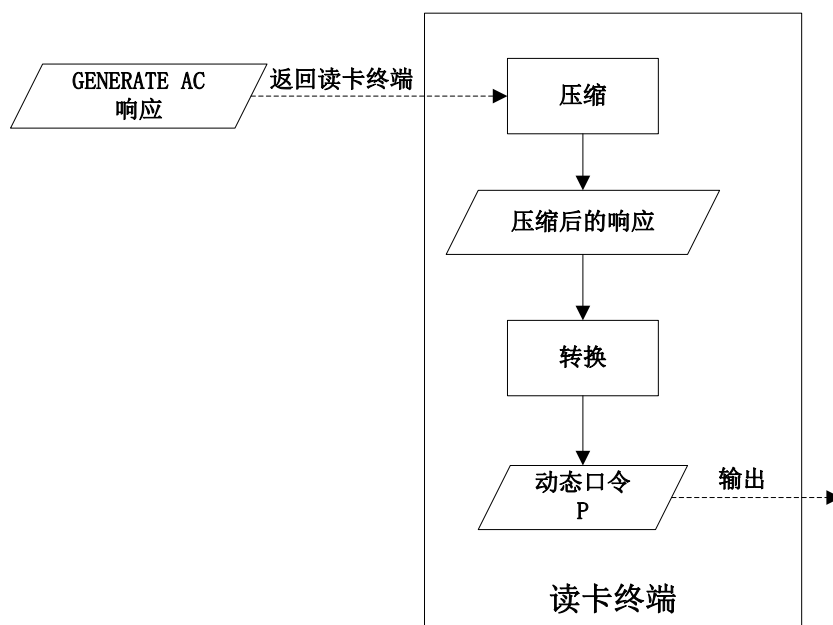


图 3：读卡终端工作原理

读卡终端接收到来自卡片的 GENERATE AC 响应后，对响应结果进行压缩，针对响应结果中 ATC、AC 和 CVR 部分选取其中的有效位以构成动态口令有效位。然后将其进行转换，其中包括 ATC 的异或、基于比特位的移位操作、以及转换为十进制数的过程，最后生成用户可以用以认证的动态口令 P。

5.4. 发卡行认证工作原理

发卡行在接收到金融 IC 卡动态口令后，需要对动态口令进行系统处理和比对。整个处理过程包括转换、数据提取、数据源的重新构建、生成 GENERATE AC 的响应、比对压缩后的 AC 等过程。

具体原理如下图所示：

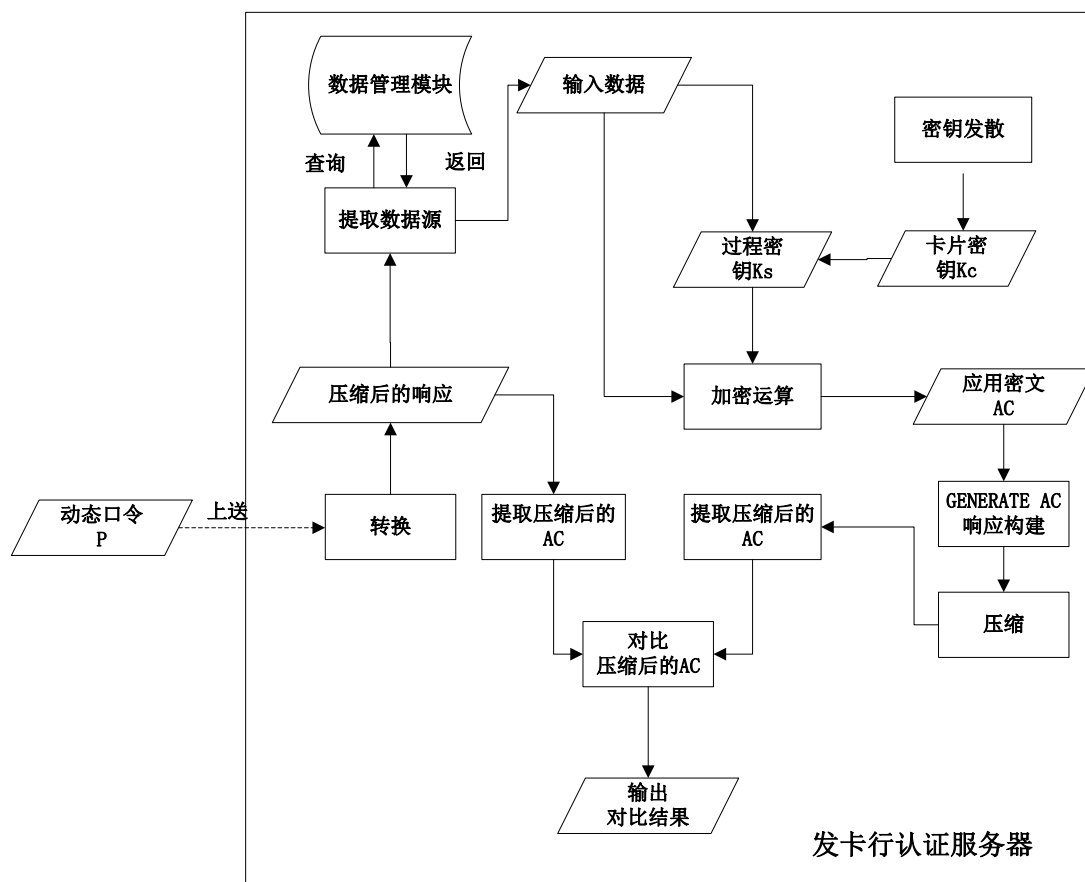


图 4：发卡行认证服务工作原理

发卡行认证服务器在接收到动态口令 P 之后，对 P 进行转换，该过程是读卡终端中转换过程的逆运算（参考第 8 部分：动态口令构建及显示），生成动态口令有效位。

然后将动态口令有效位中的 ATC（动态口令中所包含的是异或运算后的 ATC，需再用 AC 的前 15 比特进行一次异或运算，就能恢复原 ATC 值。）和 CVR 部分提取恢复出来，同时向数据管理模块查询构成数据源所需的其他信息如 AIP 等，并将完整的数据源作为输入数据。

同时，发卡行认证服务器通过应用服务器上送的用户账号或卡号，向银行密码机查询对应的主密钥 K_M ，并用 K_M 进行密钥发散，生成卡片密钥 K_C ，由 K_C 按照规定算法生成过程密钥 K_S ，使用 K_S 对规定数据进行加密运算，生成应用密文 AC。

然后，将源自动态口令 P 的压缩后的响应中的 AC 部分，与源自认证服务器的 AC 部分进行比对，并输出比对结果。

6. 业务流程

本章概述了读卡终端的业务流程。业务流程图画出了设备操作金融 IC 卡的执行顺序。

6.1. 功能概述

下面是读卡终端操作 IC 卡过程中用到的功能。整个 IC 卡的操作过程满足 Q/CUP 045.2 借记/贷记应用卡片操作流程规范，并针对读卡终端的特殊性进行了简化。

6.1.1. 应用选择

目前读卡终端定义为针对接触式借记贷记金融 IC 卡使用。因此，读卡终端固定选择 Q/CUP 045 借记/贷记应用。

6.1.2. 应用初始化

在选择了 Q/CUP 045.2 借记/贷记应用以后，读卡终端进行应用初始化处理。读卡终端通过发送获取处理选项（GP0）命令给卡片通知卡片交易处理开始。在命令中，读卡终端提供给卡片在处理选项数据对象列表（PDOL）中请求的数据元。PDOL（一个数据元标签和长度的列表）是在应用选择处理中由卡片返回给读卡终端的可选数据项。

卡片对 GP0 命令的响应信息包括：AIP 和 AFL。AIP 列出了交易在处理过程中执行的功能；AFL 列出交易需要读出的数据存放的短文件标识符、记录号、记录个数以及脱机数据认证需要的静态签名数据的存放位置。

6.1.3. 读应用数据

读卡终端按照 AFL，读取相应的记录，并从中解析出 CDOL1 和 CDOL2，供后续交易流程使用。

6.1.4. 终端行为分析

在读卡终端访问 IC 卡的交易流程中，对标准借记贷记终端行为分析进行了简化。读卡终端固定向 IC 卡发送请求脱机拒绝操作，申请 AAC。

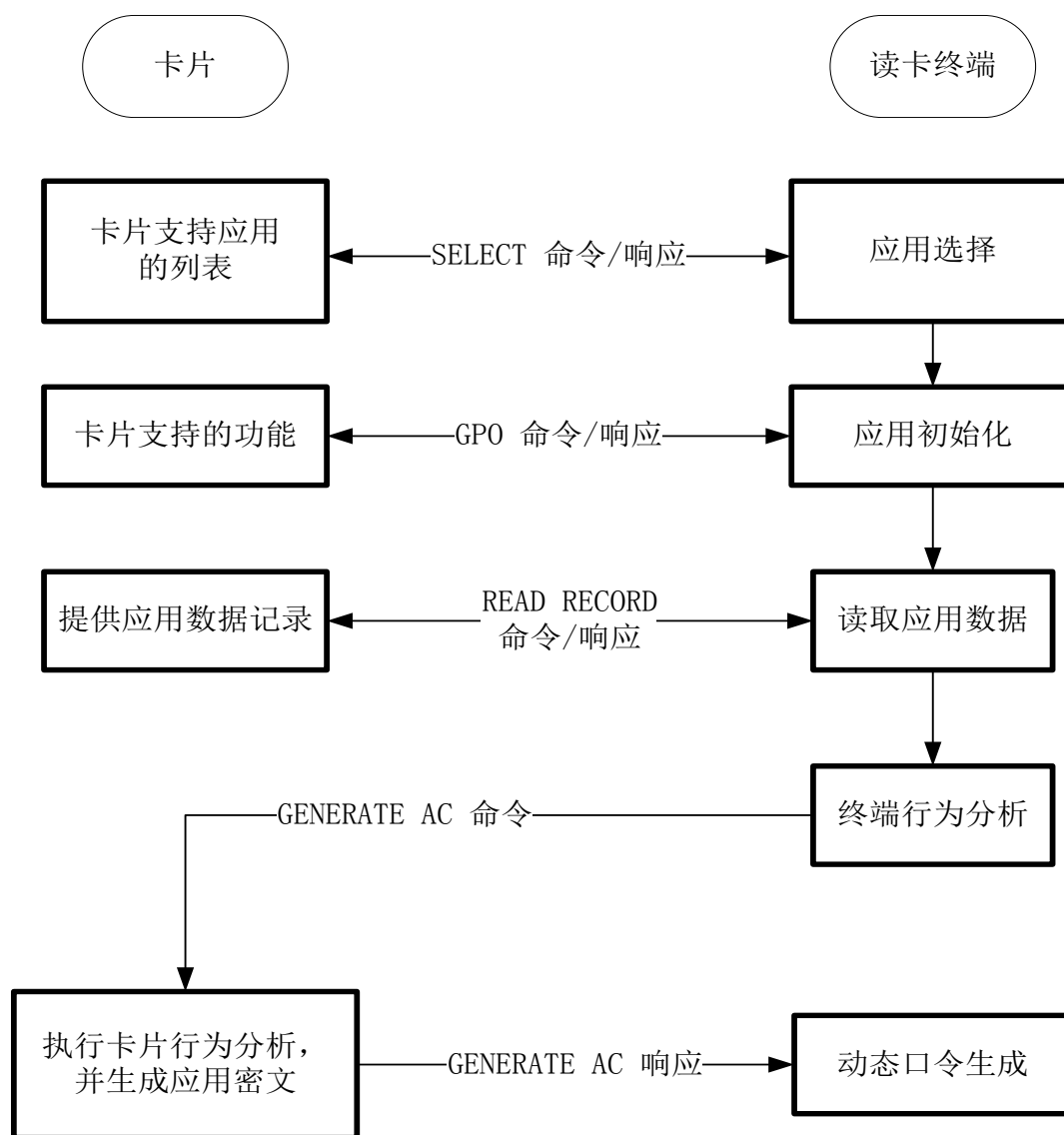
6.1.5. 动态口令生成

卡片在收到第一个 GENERATE AC 命令后，进行卡片行为分析，然后向终端返回 GENERATE AC 命令的响应数据，此时卡片的返回的应用密文为 AAC。当卡片成功返回 AAC 时，读卡终端调用动态口令生成算法生成动态口令，并进行显示。

6.1.6. 交易结束

因终端在第一个 GENERATE AC 命令中请求脱机拒绝(AAC)，因此卡片在响应第一个 GENERATE AC 命令并返回 AAC 后，交易正常结束。

6.2. 交易流程图



7. 指令与实施说明

7.1. 应用选择

7.1.1. 命令

读卡终端发送选择（SELECT）命令给卡片选择标准借记贷记应用，并获取卡片支持的应用信息。应用信息包括发卡行参数，例如：选择应用的优先级别，应用名称，首选语言。命令中固定包括标准借记贷记 AID。

命令的 P1 参数表明应用是按照名称方式选择的。P2 参数表明在支持 AID 后缀的情况下是否有另外使用同样 AID 的应用被请求（当卡片支持多应用使用同样 AID 的时候）。

命令可以有下列 SW1 SW2 返回状态字：

——9000——选择（SELECT）命令成功返回；

——6A82——在命令包含支付系统环境名称情况下，卡片不支持目录选择方式；在命令包含 AID 的情况下，表示选择的文件没有找到或已经是相同 AID 的最后一个文件而 P2 参数指定还有下一个相同 AID 的应用可选；

——6A81——卡片锁定或命令不支持；

——6283——选择文件无效。

如果卡片包含一个 PDOL，PDOL 作为 FCI 的一部分包括在选择（SELECT）命令的响应信息中。在应用初始化处理中读卡终端将 PDOL 中指定的数据送入卡片。

在选择命令成功返回后，读卡终端继续进行后续交易流程。如果选择命令返回不成功，读卡终端应立即停止此次交易流程，并提示用户交易失败。

7.1.2. 后续相关流程

应用初始化

读卡终端发送获取处理选项（GP0）命令给卡片，如果在应用选择时选择（SELECT）命令的响应信息中包括 PDOL，GP0 命令中包括 PDOL 中指定的终端数据。如果某些限制不允许选择的应用做初始化，读卡终端应立即停止此次交易流程，并提示用户交易失败。

7.2. 应用初始化

7.2.1. 命令

在应用初始化处理中，读卡终端发送获取处理选项（GP0）命令给卡片通知卡片交易处理开始。在命令中，读卡终端提供给卡片在处理选项数据对象列表（PDOL）中请求的数据元。PDOL（一个数据元标签和长度的列表）是在应用选择处理中由卡片返回给终端的可选数据项。

卡片对 GP0 命令的响应信息包括：AIP 和 AFL。AIP 列出了交易在处理过程中执行的功能；AFL 列出交易需要读出的数据存放的短文件标识符、记录号、记录个数以及脱机数据认证需要的静态签名数据的存放位置。

7.2.2. 处理流程

读卡终端读取所选应用的 SELECT 命令返回的 FCI 数据，从中解析出 PDOL。

读卡终端处理 PDOL，根据 DOL 的处理规则填入终端数据。

读卡终端向卡片发送 GP0（获取处理选项）命令，将处理 PDOL 得到的终端数据作为命令数据以 TLV 格式（标签‘83’）送给卡片。如果 PDOL 不存在，则命令数据域为“83 00”。

如果卡片返回成功（SW1 SW2 = “9000”），读卡终端读取 AIP 和 AFL，然后进行后面的读应用数据处理。

如果卡片 GP0 命令返回失败，读卡终端应立即停止此次交易，并提示用户交易失败。

7.2.3. 前期相关处理

应用选择

卡片在 SELECT 命令的响应中将 PDOL（若存在）作为 FCI 的一部分提供给终端。

7.2.4. 后续相关处理

读应用数据

读卡终端使用由卡片提供的包含在 GP0 命令响应中的 AFL，来确定从卡读取哪些应用数据并从中解析出 CDOL1 和 CDOL2。

7.3. 读应用数据

7.3.1. 命令

读卡终端向卡片发送读记录（READ RECORD）命令读取记录数据。命令参数 P2 包含所要读取文件的 SFI，P1 为所读取记录的记录号。如果返回状态 SW1 SW2 为“9000”，则响应数据域中包含请求的记录数据。

7.3.2. 处理流程

读卡终端通过 AFL 决定要从卡片中读取哪些交易数据记录，每个 AFL 项（四个字节）代表了卡片一个文件中的连续记录。对每个 AFL 项（四个字节），从第 1 条记录开始，读卡终端依次对每条记录向卡片发送一个读记录（READ RECORD）命令读取记录数据，一直到最后一条记录。如此将所有 AFL 项处理完。读卡终端从读取数据中解析出 CDOL1 和 CDOL2 用于后续交易流程中使用。

读数据处理中如果出现如下情况，交易将中止：

- 一个基本数据对象在卡片中出现超过一次；
- 卡片中缺少 CDOL1 和 CDOL2 数据；
- 数据格式错；
- READ RECORD 命令返回状态字不是“9000”

7.3.3. 前期相关处理

应用初始化

读卡终端从获取处理选项（GP0）命令的响应中得到应用的 AFL 用于读取应用数据。

7.3.4. 后续相关处理

终端行为分析

7.4. 终端行为分析

7.4.1. 概述

在读卡终端访问 IC 卡的交易流程中，对标准借记贷记终端行为分析进行了简化。读卡终端固定向 IC 卡发送请求联机，申请 AAC 的指令。

7.4.2. 命令

读卡终端固定向卡片发送第一次 GenerateAC 指令,并将命令的 P1 参数固定设置为 0x00. 命令的数据域按照 CDOL1 所定义的数据顺序进行组合。

7.4.3. 处理流程

简化标准借记贷记终端行为分析流程,固定向卡片发送 GenerateAC,请求 AAC 指令。

7.4.4. 前期相关处理

读取应用数据

读卡终端从卡片读取应用数据。此数据包括卡片风险管理数据对象列表 1 (CDOL1) 和卡片风险管理数据对象列表 2 (CDOL2)

7.4.5. 后续相关处理

动态口令生成

卡片行为分析中,卡片执行附加的风险管理来决定是否同意终端请求联机的决定。如果卡片请求联机,读卡终端调用动态口令生成算法,生成动态口令并显示。

7.5. 动态口令有效数据生成

7.5.1. 命令

卡片在卡片行为分析的最后向终端返回 GENERATE AC 命令的响应数据,此时卡片的返回的应用密文仅可能为 AAC。详细说明可以参见 Q/CUP 045.2 GENERATE AC 命令格式一的返回。

7.5.2. 处理流程

卡片在收到第一个 GENERATE AC 命令后(请求 AAC),按照标准借记贷记交易流程进行卡片行为分析。并返回响应数据。

读卡终端判断卡片响应数据,如果出现下列现象之一,交易终止:

- 1、卡片返回数据格式不正确。
- 2、GENERATE AC 指令返回失败。

如果卡片成功生成并返回 AAC,读卡终端调用动态口令生成算法(包括压缩)生成动态口令,并显示。

7.5.3. 前期相关处理

读取应用数据

读卡终端从卡片读取卡片风险管理数据对象列表 1 (CDOL1)。

读卡终端根据终端行为分析的结果向卡片请求 AAC 并向卡片提供其在 CDOL1 中请求的终端数据。

7.5.4. 后续相关处理

交易结束

7.6. 交易结束

7.6.1. 概述

在动态口令生成并显示完成后，本次交易中读卡终端对 IC 卡的操作完成。

7.6.2. 前期相关处理

卡片行为分析

卡片在第 1 个 GENERATE AC 命令的响应中返回 AAC。

7.7. 交易过程中所需数据

7.7.1. CDOL1、CDOL2、PDOL 涉及到的数据定义

数据元	来自终端的数据	卡片内数据	数据来源
授权金额	V		键盘输入（事件型默认为全 00）（6 字节）
其它金额	V		固定 000000 （6 字节）
终端国家代码	V		固定 0156
终端验证结果	V		固定 0000000000
交易货币代码	V		固定 0156
交易日期	V		固定 000000
交易类型	V		固定 0
不可预知数	V		键盘输入（4 字节） （事件型默认为全 00）
应用交互特征（AIP）		V	
应用交易计数器（ATC）		V	

卡片验证结果 (CVR)		V	
--------------	--	---	--

除以上列出的数据元外，如果 CDOL1、CDOL2、PDOL 还包含其它数据参数，可以默认取值为 0。

7.7.2. CVR 数据定义

字节 1：固定为 3

字节 2：

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	说明
1	0							不请求第 2 个 GENERATE AC
		0	0					第 1 个 GENERATE AC 返回 AAC
				0				发卡行认证执行但失败
					0			脱机 PIN 执行
						0		脱机 PIN 认证失败
							0	不能联机

字节 3

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	说明
X								上次联机交易没有完成
	0							PIN 锁定
		X						超过频率检查
			0					新卡
				X				上次联机交易

								发卡行认证失败
					X			联机授权后，发卡行认证没有执行
						0		由于PIN锁卡片锁定应用
							0	上次交易 SDA 失败交易拒绝

字节 4

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	说明
0	X	X	X					上次交易第2个生成应用密文命令后收到的带有安全报文的发卡行脚本命令
				X				上次交易发卡行脚本处理失败指针
					0			上次交易 DDA 失败交易拒绝
						0		DDA 执行
							0	RFU (0)

8. 动态口令构建及显示

8.1. 加密算法

本规范中涉及的卡片和发卡行认证服务器中所有密钥发散算法与加密算法,均应该符合《中国银联IC卡技术规范》的相关要求。

8.2. 动态口令有关数据构建

本规范所提到的动态口令是选择 GENERATE AC 响应中的有效位并经转换构成的:

GENERATE AC 响应总长至少为 18 个字节 (其中 CID 1 个字节, ATC 2 个字节, AC 8 个字节, IAD 7 个字节), IAD 部分的长度只取长度指示符、分散密钥索引、密文版本号、卡片验证结果 (CVR), 如 GENERATE AC 响应中的 IAD 长度大于 7 个字节, 本规范只选用前面 7 个字节。

具体结构如下图所示:

GENERATE AC 响应的结构	CID	ATC	AC	IAD
----------------------	-----	-----	----	-----

8.3. 动态口令有效位选择

根据动态口令的需要, 选择 GENERATE AC 响应中对应位置上的数据, 按照原有的数据进行重新组装, 形成动态口令有效位。

本规范中选定的有效数据如下图所示, 16 进制转化成 2 进制后 1 对应的位即为有效位:

00	7F FF	FF FF 00 00 00 00 00 00	00 00 00 00 00 AC 78
CID	ATC	AC	IAD

如上图所示, ATC 部分有 15 个有效位, 相当于一个计数周期包含 32767 次交易; AC 部分有 16 个有效位, 位置为 AC 部分的前两个字节; IAD 部分有 8 个有效位¹⁾, 均在 CVR 部分。一共 39 位。

8.4. ATC 异或

为避免新卡时 ATC 前几位总是 0, 使得由此构建的动态口令前几位随机性不够, 本规范要求将 ATC 进行异或后再参与动态口令构建和显示:

将 ATC 部分 (15 比特), 与 AC(16 比特)中的前 15 比特数据 (高位在前), 进行异或运算, 所得数据为新的 ATC 部分数据 (15 比特)。

举例: 原 ATC: 1001 1100 0011 010

AC: 1100 0101 1000 0011

AC 用于异或运算的前 15 个比特: 1100 0101 1000 001

异或运算后的 ATC: 0101 1001 1011 011

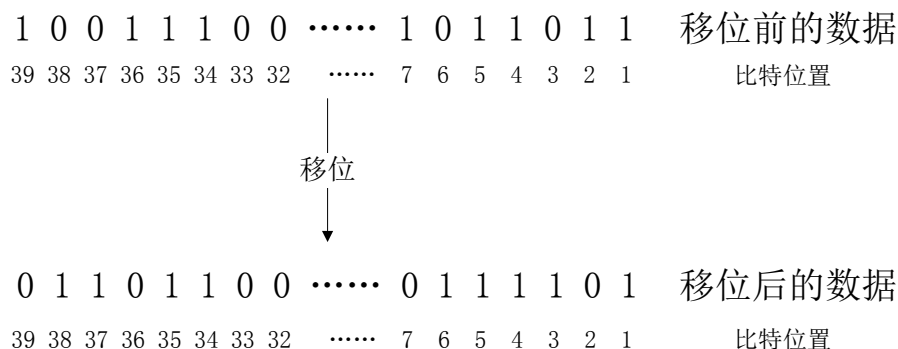
然后根据“8.3 动态口令有效位选择”中 GENERATE AC 响应的格式, 重新将 ATC 部分, AC, CVR 部分进行组装, 得到最终的动态口令有效位数据。

8.5. 有效位移位规则

¹⁾ 本规范中选择的 CVR 部分的 8 个有效位仅为金融 IC 卡动态密码应用的基本要求, 发卡行可根据自身风险判断和产品个性化需求, 适当增加有效位长度, 由此构成的动态密码的长度也将相应增加。

为提高动态口令的随机性，本规范要求将动态口令有效位数据进行移位后再显示。

移位方法：将 39 个比特位中的奇数位与它右侧的偶数位进行互换（第一个比特位不操作），具体如下图所示：



如上图所示，第 1 个比特位不操作，第 3 个比特位与第 2 个比特位互换，同样的移位操作一直进行至第 39 位，即一直到第 39 个比特位与第 38 个比特位互换结束。移位操作后，所得的数据为移位后的数据结果，也即动态口令数据。

8.6. 动态口令显示

读卡终端将移位后的 2 进制数据转换成 10 进制数字显示，39 个比特位 2 进制数显示成 10 进制数后应为 12 位。

可选不同显示做法：因 12 位数字较长，可以考虑转换成 32 进制数(以数字+字母形式)在屏幕上显示，用 8 位字符即可表示，方便持卡人输入，并能支持更长的有效位数，但不适用于电话键盘输入。具体原理如下：

- a) 39 个指定位从低位起，向高位每 5 位转换成一个数字；
- b) 上述数字用以下 32 进制数表示：

十进制数	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
32 进制数	0	1	2	3	4	5	6	7	8	9	A	C	D	E	F	G
十进制数	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
32 进制数	H	J	K	L	M	N	P	R	S	T	U	V	W	X	Y	Z

- c) 注：为了不让持卡人将字母与数字混淆，字母 B(同数字 8)，I(同数字 1)，O 和 Q(同数字 0) 均已剔除。
- d) 此种方式下，可适当增加有效位的个数。

9. 发卡行认证服务

9.1. 认证服务介绍

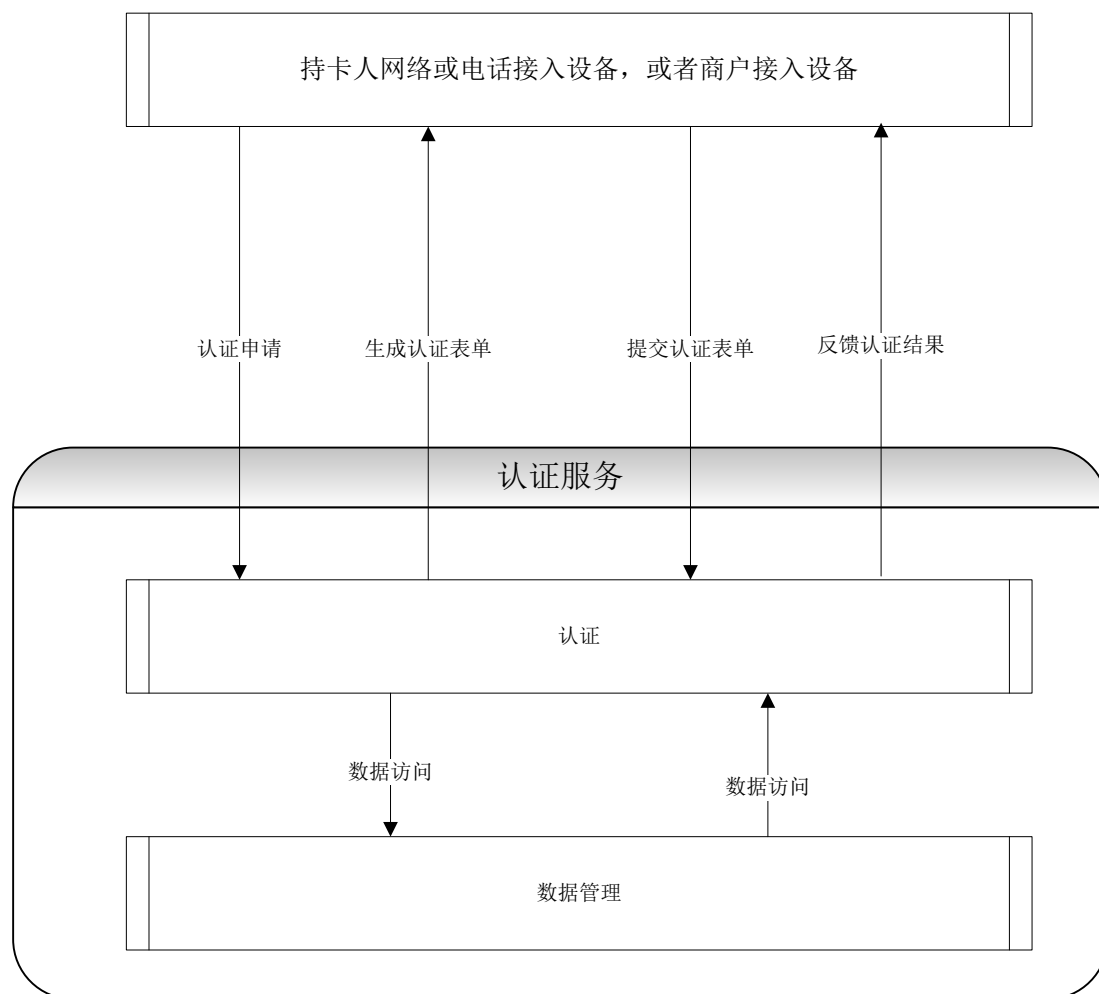
发卡行认证服务指发卡行验证金融 IC 卡在手持终端上所产生的动态口令的真伪，由以下功能组成：

- 数据管理——存储和维护验证动态口令所需要的卡片信息，包括计算 AC 所需要的密钥。
- 接受认证请求。

- 验证动态口令。
- 反馈认证结果。
- 根据不同的模式，认证服务还可以生成持卡人认证表单。

持卡人认证表单指根据当前交易情况生成的持卡人需要填入的数据，如动态口令，转账金额、账号等。认证服务生成持卡人认证表单，把它发送到持卡人的网络接入设备。持卡人需要填入相关的数据，包括动态口令，再把这些数据提交给认证服务。如果是电话订单，那么商户应该代表持卡人完成认证表单。

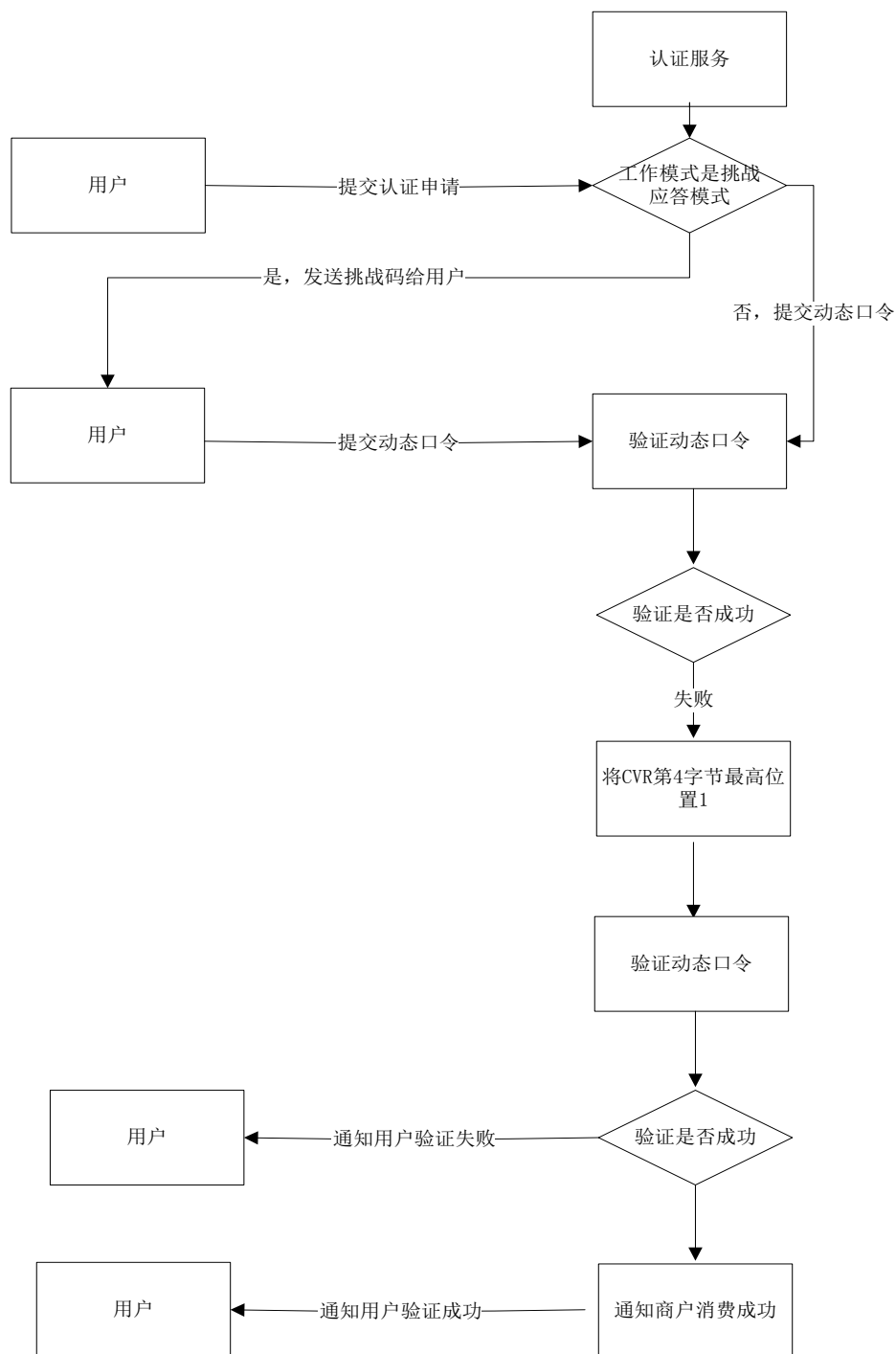
9.2. 认证服务基本框架示意图



持卡人通过网络或电话接入设备向认证服务提出认证申请，认证服务根据不同的交易模式，可以有选择的生成认证表单（指需要填写的认证信息，如帐号、交易金额等），用户填写认证表单后（表单中包含动态口令），把表单提交给认证服务，发卡行进行验证后，把结果反馈给用户。

认证服务在验证过程中，需要通过数据管理来访问验证所必须的卡片信息。

9.3. 认证服务参考流程



上图中的“验证动态口令”操作，具体内容可以参考章节 5.4，认证原理部分。

9.4. 失步处理

在动态口令上传时，受长度限制，卡片数据 CVR 中的字节 4 最高位并没有上传，默认按 0 计算。这样当该位为 1 时，会导致认证服务验证失败。为了解决这个问题，在认证服务第一次验证失败时，认证服务会把该位置 1，重新进行验证。如果两次都失败，那么认证服

务将结果返回给用户。

9.5. 数据管理

9.5.1. 卡片数据

TAG	值	来源
CID	0x80	默认值
CVN	N/A	发卡行，通过数据管理获得
DKI	N/A	发卡行，通过数据管理获得
AIP	N/A	发卡行，通过数据管理获得
ATC	N/A	动态口令上传
CVR	N/A	部分为默认值，部分动态口令上

CVR 的详细说明如下，其中本规范中推荐的有效位由动态口令上传：

卡片验证结果 (CVR) F: b 32 T: - L: 4.	字节 1: 长度字节 03	默认值 0x03
	字节 2:	
	bits 8-7:	默认值 0x10
	00 = 第二个 GENERATE AC 返回 AAC	
	01 = 第二个 GENERATE AC 返回 TC	
	10 = 不请求第二个 GENERATE AC	
	11 = RFU	
	bits 6-5:	默认值 0x00
	00 = 第一个 GENERATE AC 返回 AAC	
	01 = 第一个 GENERATE AC 返回 TC	
	10 = 第一个 GENERATE AC 返回 ARQC	
	11 = 不能返回 11	
	bit 4: 1 = 发卡行认证执行但失败	默认值为 0
	bit 3: 1 = 脱机 PIN 执行	默认值为 0
	bit 2: 1 = 脱机 PIN 认证失败	默认值为 0
	bit 1: 1 = 不能联机	默认值为 0

验证结果 (CVR) (继续)	字节 3: bit 8: 1 = 上次联机交易没有完成 bit 7: 1 = PIN 锁定 bit 6: 1 = 超过频率检查 bit 5: 1 = 新卡 bit 4: 1 = 上次联机交易发卡行认证失败 bit 3: 1 = 联机授权后, 发卡行认证没有执行 bit 2: 1 = 由于 PIN 锁卡片锁定应用 bit 1: 1 = 上次交易 SDA 失败交易拒绝 字节 4: bits 8-5: 上次交易第二个 GENERATE AC 命令后收到的带有安全报文的发卡行脚本命令 bit 4: 1 = 上次交易发卡行脚本处理失败指针 bit 3: 1 = 上次交易 DDA 失败交易拒绝 bit 2: 1 = DDA 执行 bit 1: RFU (0)	由动态口令上传 默认值为 0 由动态口令上传 默认值为 0 由动态口令上传 由动态口令上传 默认值为 0 默认值为 0 Bit8 默认值为 0 Bit 7-5 由动态口令上传 由动态口令上传 默认值为 0 默认值为 0 默认值为 0
-----------------------	---	---

9.5.2. 终端数据

参考“7.7.1. CDOL1、CDOL2、PDOL 涉及到的数据定义”

9.6. 算法

认证服务器涉及到的算法包括, 计算应用密文算法, 过程密钥算法, 压缩算法, 移位算法。

计算密文算法:

参看《中国银联 IC 卡技术规范——基础规范》第 4 部分, 附录 D。

过程密钥算法:

参看《中国银联 IC 卡技术规范——基础规范》第 4 部分, 附录 C。

压缩算法:

参看本规范第 8 章 动态口令构建及显示。

移位算法:

参看本规范第 8 章 动态口令构建及显示。

9.7. 风险管理

为进一步加强动态口令的安全性, 避免动态口令被提前获知后的伪冒使用, 发卡行应对每次动态口令上送的 ATC 也就是交易次数进行判断, 判断的标准为本次交易的 ATC 必须大于上次动态口令交易或联机交易 (pos、atm) 所上送的 ATC, 不满足此条件时应验证不成功,

要求持卡人重新生成动态口令，直至 ATC 大于之前交易的 ATC 后才能满足验证成功。

当出现动态口令上送的 ATC 小于系统中记录的上次交易的 ATC 的情况时，建议发卡行对持卡人进行联络，以确认该张卡是本人使用。

建议发卡行对大额和集中发生的交易采用较复杂的应用模式（如挑战型或交易签名模式，可参考附录）生成动态口令，以进一步加强对当前交易的验证性。

10. 其他要求

10.1. 读卡终端硬件要求

10.1.1. 显示屏

应通过显示屏一次性显示动态口令数字或字符。

10.1.2. 输入

应具备 10 个数字的输入能力以及相应的纠正改错、确认输入。

需具备模式切换功能输入，便于用户在不同动态口令模式下的切换。

10.1.3. IC 卡读卡器

要求具备接触式 IC 卡插口，用来接受用户 IC 卡插入并与 IC 卡进行命令数据传递通讯。

建议终端的用户卡 IC 卡读卡器插槽附近有一明显标记指示如何插入 IC 卡。如果终端有锁卡或吞卡功能，则应保证在掉电、设备异常或交易取消时能释放或退出卡。

需同时应支持 $t=0$ 和 $t=1$ 的卡。

10.1.4. 电池

读卡终端应具备电池，建议使用通用的电池类型。

10.2. 读卡终端软件要求

具备对软硬件的自检及报错功能，卡片检测并上电运行功能。

从最终确认输入起，到动态口令显示时间间隔不得超过 2s。

10.3. 读卡终端安全要求

鉴于该设备的使用环境属于无敏感信息的输入（如 PIN、卡号），无关键信息的存储，使用环境的独立性（除与 IC 交互外，无外部数据的交互环节），读卡器无需特殊安全级别进行保证。

须符合 ISO/IEC 7816 和 EMV 有关要求。

10.4. 余额查询

读卡终端应具备电子现金余额查询功能。

附录：应用模式推荐

本部分推荐金融 IC 卡动态口令的三种应用模式：事件型认证模式，挑战型认证模式和交易签名模式供参考，机构应根据实际业务需要设计和丰富自身产品的具体应用模式。

1. 事件型（或称为默认型）认证模式

指不需持卡人或发卡行干预或提供输入数据，直接通过默认数据生成动态口令。操作最为简单，比较适合简单的查询登录或低风险商户。

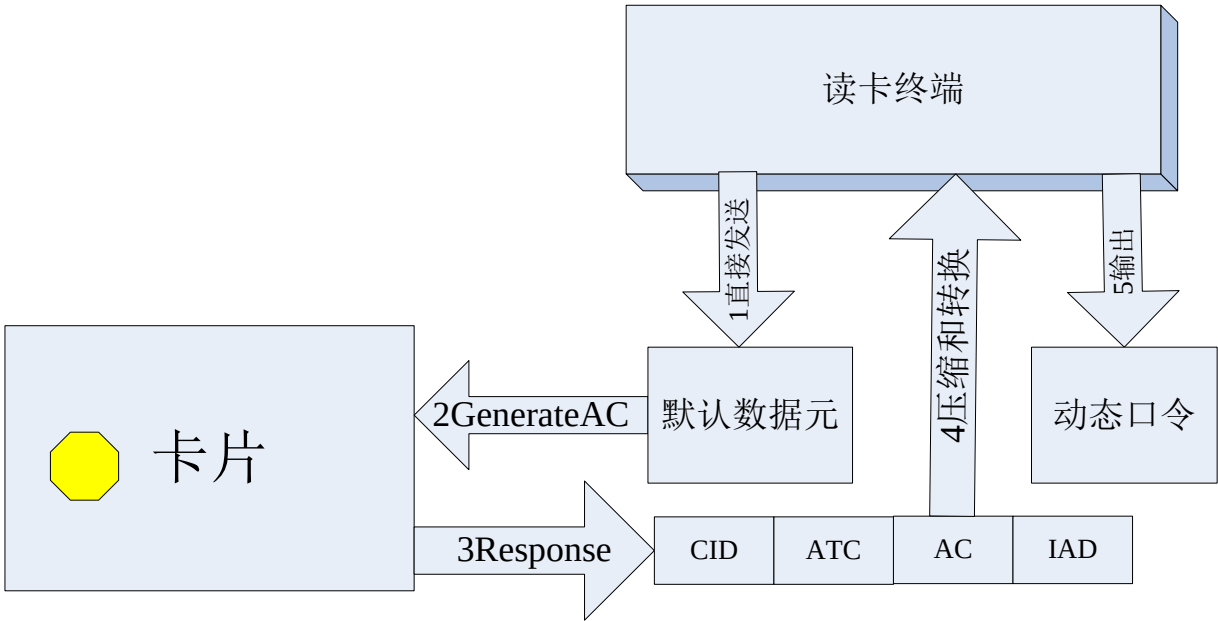


图 5：事件认证工作原理

每次认证请求时，用户不进行任何外部数据输入操作，读卡终端向卡片发送预置的默认数据元(见附录 1)来进行 GenerateAC 操作。卡片返回 ATC 和应用密文 AC 给读卡终端，读卡终端将获取的数据进行压缩和转换后得到动态口令。

读卡终端发给卡片的数据全部为默认值，为：

默认数据元	来自终端的数据
授权金额	默认值
其它金额	默认值
终端国家代码	默认值
终端验证结果	默认值
交易货币代码	默认值
交易日期	默认值
交易类型	默认值
不可预知数	默认值

2. 挑战型认证模式

指需要持卡人或发卡行提供输入数据，将此数据输入卡片后，由卡片根据输入数据生成动态口令。安全性较高，比较适合一般商户消费使用。

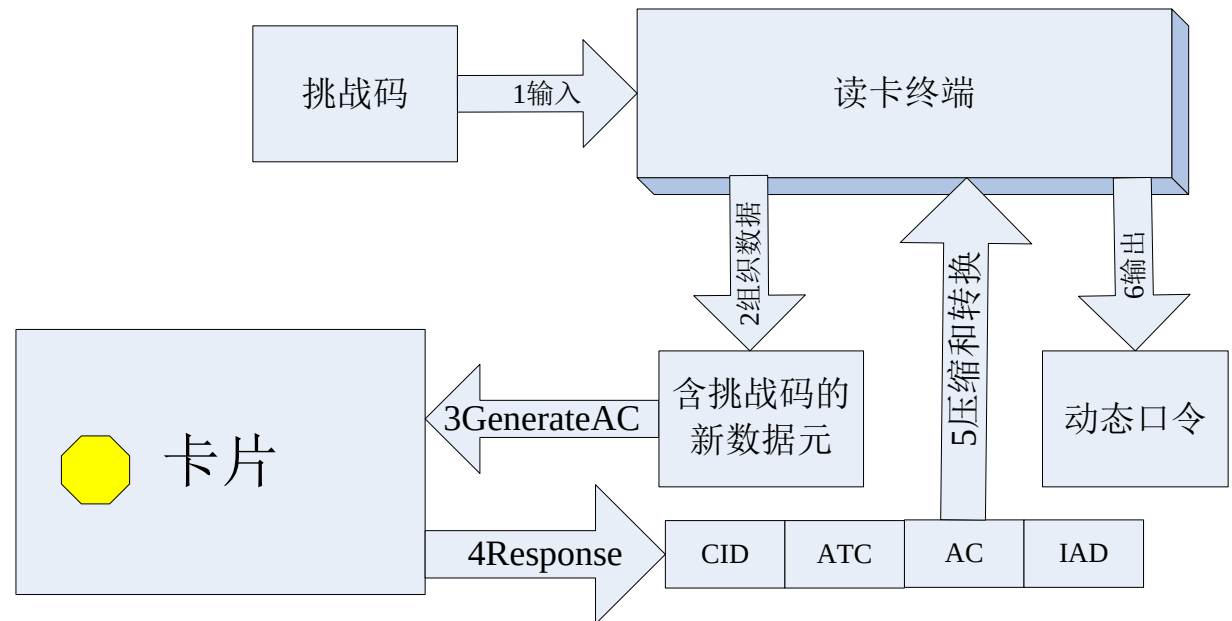


图 6：挑战认证工作原理

每次认证请求时，用户根据提示输入发卡行提供的挑战码，挑战码多为随机数。读卡终端得到输入的挑战码后重新组织数据元，将默认数据元的不可预知数字段替换为输入的挑战码。读卡终端将组织后的新数据发给卡片进行 **GenerateAC** 操作。卡片返回 **ATC** 和应用密文 **AC** 给读卡终端，读卡终端将获取的数据进行压缩和转换后得到的动态口令。

假设挑战码为 **1234**（不超过 8 位十进制数字，不足 8 位的前补 0），被发送到卡片的数据元为：

默认数据元	来自终端的数据
授权金额	默认值
其它金额	默认值
终端国家代码	默认值
终端验证结果	默认值
交易货币代码	默认值
交易日期	默认值
交易类型	默认值
不可预知数	00001234

3. 交易签名模式

交易签名模式根据输入的数据内容不同分为两类，一类是输入交易信息，另一类是输入转账帐号信息，也可以输入身份证或订单号等，适合大额或特定场合的安全认证。

输入交易信息

每次认证请求时，用户根据提示输入授权金额。读卡终端用输入数据重新组织数据元，将默认的数据元中授权金额字段替换为输入的授权金额。读卡终端将组织后的新数据发给卡片进行 **GenerateAC** 操作。卡片返回 **ATC** 和应用密文 **AC** 给读卡终端，读卡终端将获取的数据进行压缩和转换后得到的动态口令。

授权金额：数值型，以分为基本单位，格式为 **n12**。n—数字型，也称作 BCD 码。右对齐，左补‘0’。如，数字 123.45 可以保存在 n12 的授权金额数据对象中，形如‘00 00 00 01 23 45’。

如授权金额为 123.45 元，被发送给卡片的数据源为：

默认数据元	来自终端的数据
授权金额	000000012345
其它金额	默认值
终端国家代码	默认值
终端验证结果	默认值
交易货币代码	默认值
交易日期	默认值
交易类型	默认值
不可预知数	默认值

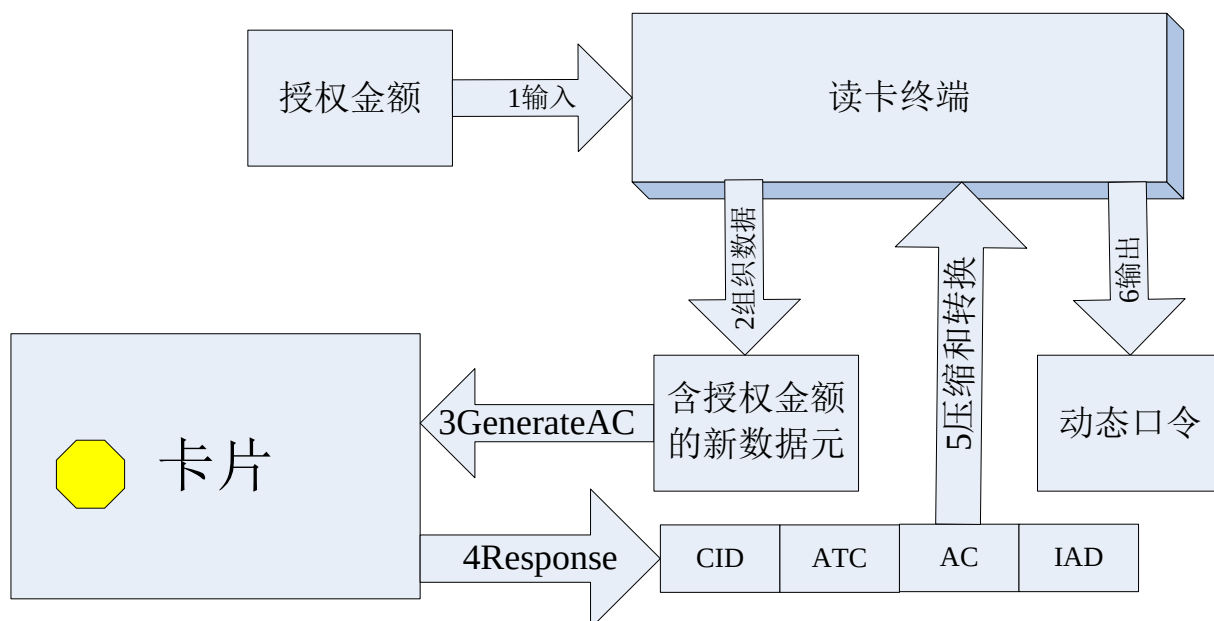


图 7：交易信息认证工作原理

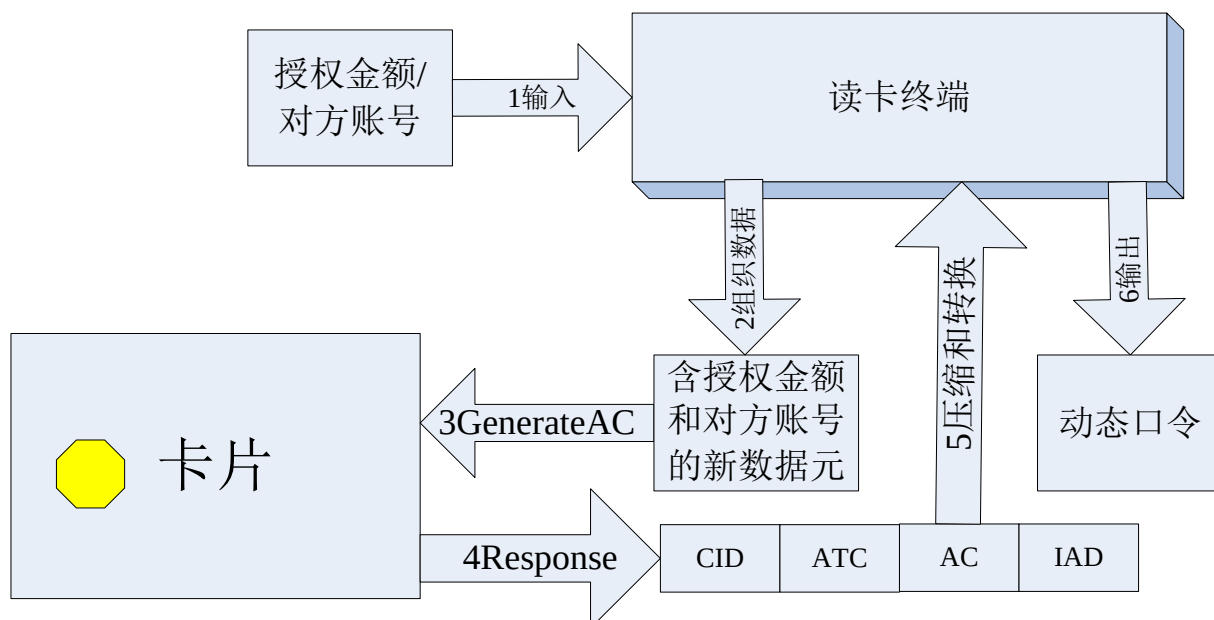
输入转账帐号

为有效防范钓鱼网站的欺诈，在转账时增加一种交易签名模式，将转入帐号的信息部分纳入到签名数据中：

将转账过程中，将转账金额填入数据源“授权金额”，并将对方的卡号最后 8 位数字填入数据源中“不可预知数”，用于 AC 的计算。读卡终端将组织后的新数据发给卡片进行 GenerateAC 操作。卡片返回 ATC 和应用密文 AC 给读卡终端，读卡终端将获取的数据进行压缩和转换后得到的动态口令。

如转账 798 元，对方的账号为 6226100200311400567，被发送给卡片的数据源为：

默认数据元	来自终端的数据
授权金额	000000079800
其它金额	默认值
终端国家代码	默认值
终端验证结果	默认值
交易货币代码	默认值
交易日期	默认值
交易类型	默认值
不可预知数	11400567



4. 交易举例

持卡人登录网银进行资金转账：

- 持卡人在网页上输入转账帐户名称和转账金额；
 - 银行要求持卡人使用动态口令确认他/她的资金转移；
 - 持卡人将 UICS 金融 IC 卡插入动态口令终端；
 - 持卡人按终端上的转账口令生成键；
 - 银行提示持卡人输入交易参数:交易金额、对方帐号；
 - 持卡人将交易参数输入动态口令终端；
 - UICS 金融 IC 卡生成一个动态的、不可重复使用的和唯一的交易签名；
 - 交易签名由动态口令终端转换后成数字后显示在动态口令终端屏幕上；
 - 动态口令被持卡人输入到网银；
 - 动态口令被持卡人的发卡银行验证是否合法；
 - 验证交易合法的完成转账，交易结束。
-